Name of Organisation **SOA ISO/IEC 27001:2017**

Statement of Applicability: Patient Health Data

Highlighted main control that must be adopted.

A.5 Information Security Policies

A .5.1 Management Direction for Information Security

Control	Description	Adopted	Justification	Reference
A.5.1.1	Policies for information security	Y	Policies govern secure handling of high-risk patient data protected under GDPR.	Information Security Policy Manual
A.5.1.2	Review of the policies for information security	Y	Patient data policies are reviewed regularly to reflect GDPR changes and emerging risks.	Information Security Policy Manual

A.6 Organisation of Information Security

A.6.1 Internal Organisation

Control	Description	Adopted	Justification	Reference
A.6.1.1	Information security roles and responsibilities	Y	Defined roles for managing patient data or reduce risk of oversight	Information Security Policy Manual

A.6.1.2	Segregation of duties	Y	Data access and auditors are separated to minimise risk	ISMS Operational Manual
A.6.1.3	Contact with authorities	Y	Required for reporting data breaches involving health records	Incident Response Procedure
A.6.1.4	Contact with special interest groups	N	Not relevant.	N/A
A.6.1.5	Information security in project management	Y	Security considerations are integrated into systems that handle patient data	Governance and Continuity Framework

A.6.2 Mobile Devices and Teleworking

Control	Description	Adopted	Justification	Reference
A.6.2.1	Mobile device policy	Y	mobile access to patient data is governed by encryption app use policies	Staff Handbook
A.6.2.2	Teleworking	Y	remote access to patient records is secured	Staff Handbook

A.7 Human Resource Security

A.7.1 Prior to Employment

Control	Description	Adopted	Justification	Reference
A.7.1.1	Screening	Y	Staff with access to patient data are background checked.	Staff Handbook
A.7.1.2	Terms and conditions of employment	Y	Employment contracts include data protection responsibilities.	Staff Handbook

A.7.2 During Employment

Control	Description	Adopted	Justification	Reference
A.7.2.1	Management responsibilities	Y	Managers are accountable for data handling within their teams.	Staff Handbook
A.7.2.2	Information security awareness, education and training	Y	Staff trained on patient data handling and data protection.	Staff Handbook
A.7.2.3	Disciplinary process	Y	Breaches of patient data policy are subject to discipline.	Staff Handbook

A.7.3 Termination and Change of Employment

Control	Description	Adopted	Justification	Reference
A.7.3.1	Termination or change of employment responsibilities	Y	Data access is revoked when roles change or employment ends.	ISMS Operational Manual

A.8 Asset Management

A.8.1 Responsibility for Assets

Control	Description	Adopted	Justification	Reference
A.8.1.1	Inventory of assets	Y	Patient data is listed in the asset register.	Governance and Continuity Framework
A.8.1.2	Ownership of assets	Y	Data assigned for patient records.	ISMS Operational Manual
A.8.1.3	Acceptable use of assets	Y	Staff follow defined rules for patient data use.	Information Security Policy Manual
A.8.1.4	Return of assets	Y	Data access revoked when roles change or end.	ISMS Operational Manual

A.8.2 Information Classification

Control	Description	Adopted	Justification	Reference
A.8.2.1	Classification of information	Y	Patient data is classified as sensitive personal data.	ISMS Operational Manual
A.8.2.2	Labelling of information	Y	Sensitive records marked as “confidential” in system.	ISMS Operational Manual
A.8.2.3	Handling of assets	Y	Staff trained on how to handle patient data securely.	Staff Handbook

A.8.3 Media Handling

Control	Description	Adopted	Justification	Reference
A.8.3.1	Management of removable media	N	Patient data not stored on removable media.	N/A
A.8.3.2	Disposal of media	Y	Secure deletion procedures followed for obsolete records.	ISMS Operational Manual
A.8.3.3	Physical media transfer	N	Patient data not transferred using physical media.	N/A

A.9 Access Control

A.9.1 Business Requirements of Access Control

Control	Description	Adopted	Justification	Reference
A.9.1.1	Access control policy	Y	Policy defines how access to patient data is controlled and enforced.	Information Security Policy Manual
A.9.1.2	Access to networks and network services	Y	Network access to patient data systems is role based and restricted.	Information Security Policy Manual

A.9.2 User Access Management

Control	Description	Adopted	Justification	Reference
A.9.2.1	User registration and de-registration	Y	All users accessing patient data must be registered and deregistered promptly	ISMS Operational Manual
A.9.2.2	User access provisioning	Y	access to patient data is provisioned according to defined roles.	Information Security Policy Manual
A.9.2.3	Management of privileged access rights	Y	Privileged access to patient systems is limited and documented.	ISMS Operational Manual
A.9.2.4	Management of secret authentication information of users	Y	Authentication credentials are securely stored and maintained.	Information Security Policy Manual
A.9.2.5	Review of user access rights	Y	Access rights for users of patient data are reviewed regularly.	ISMS Operational Manual
A.9.2.6	Removal or adjustment of access rights	Y	Access to patient data is removed or adjusted when roles change.	ISMS Operational Manual

A.9.3 User Responsibilities

Control	Description	Adopted	Justification	Reference
A.9.3.1	Use of secret authentication information	Y	Users are trained to securely handle authentication information.	Security Awareness Manual

A.9.4 System and Application Access Control

Control	Description	Adopted	Justification	Reference

A.9.4.1	Information access restriction	Y	Patient data access is restricted using system level access controls.	ISMS Operational Manual
A.9.4.2	Secure log-on procedures	Y	Log on procedures ensure secure access to patient data systems.	ISMS Operational Manual
A.9.4.3	Password management system	Y	Password rules are enforced for system storing patient records.	Information Security Policy Manual
A.9.4.4	Use of privileged utility programs	Y	Privilege utilities are restricted to authorised system administrators.	ISMS Operational Manual
A.9.4.5	Access control to program source code	Y	Not applicable to patient data which does not involve source code access.	N/A

A.10 Cryptography

A.10.1 Cryptographic Controls

Control	Description	Adopted	Justification	Reference
A.10.1.1	Policy on the use of cryptographic controls	Y	Encryption is required to protect health data well stored and during transmission.	Information Security Policy Manual
A.10.1.2	Key management	Y	Keys for encrypted health data are securely generated stored.	Information Security Policy Manual

A.11 Physical and Environmental Security

A.11.1 Secure Areas

Control	Description	Adopted	Justification	Reference

A.11.1.1	Physical security perimeter	N	Data is cloud based and not dependent on perimeter controls.	N/A
A.11.1.2	Physical entry controls	Y	Entry to offices handling health data is access controlled.	Staff Handbook
A.11.1.3	Securing offices, rooms and facilities	Y	Rooms with access to data are locked and access restricted.	Staff Handbook
A.11.1.4	Protecting against external and environmental threats	Y	Critical areas have basic environmental controls, such as emergency power solutions and locked access points.	Governance and Continuity Framework
A.11.1.5	Working in secure areas	Y	Access to health data is only permitted in secure locations.	Information Security Policy Manual
A.11.1.6	Delivery and loading areas	N	Not relevant	N/A

A.11.2 Equipment

Control	Description	Adopted	Justification	Reference
A.11.2.1	Equipment siting and protection	Y	Equipment is located unprotected to reduce risk from access or environmental threats.	ISMS Operational Manual
A.11.2.2	Supporting utilities	N	Not applicable.	N/A
A.11.2.3	Cabling security	N	Not relevant.	N/A
A.11.2.4	Equipment maintenance	N	Devices are replaced instead of maintained.	N/A
A.11.2.5	Removal of assets	Y	Devices are returned or access removed when roles change.	ISMS Operational Manual
A.11.2.6	Security of equipment and assets off-premises	Y	Off-premises equipment is protected to prevent unauthorised access.	Staff Handbook
A.11.2.7	Secure disposal or re-use of equipment	Y	Devices are securely wiped before disposal or reuse.	ISMS Operational Manual
A.11.2.8	Unattended user equipment	Y	Devices unlocked when unattended.	ISMS Operational Manual

A.11.2.9	Clear desk and clear screen policy	Y	Staff follow screen and desk policy to protect visible data.	Staff Handbook

A.12 Operations Security

A.12.1 Operational Procedures and Responsibilities

Control	Description	Adopted	Justification	Reference
A.12.1.1	Documented operating procedures	Y	Procedures guide how patient data is handled and accessed.	ISMS Operational Manual
A.12.1.2	Change management	Y	Changes to data systems follow a review process.	ISMS Operational Manual
A.12.1.3	Capacity management	N	Not relevant.	N/A
A.12.1.4	Separation of development, testing and operational environments	N	Not applicable.	N/A

A.12.2. Protection from Malware

Control	Description	Adopted	Justification	Reference
A.12.2.1	Controls against malware	Y	Devices used for health data have anti malware software.	Device security SOP

A.12.3 Backup

Control	Description	Adopted	Justification	Reference
A.12.3.1	Information backup	Y	Patient data is backed up regularly to ensure availability.	ISMS Operational Manual

A.12.4 Logging and Monitoring

Control	Description	Adopted	Justification	Reference
A.12.4.1	Event logging	Y	Access to health data is logged for trace ability.	ISMS Operational Manual
A.12.4.2	Protection of log information	Y	Logs are secured against tampering or loss.	ISMS Operational Manual
A.12.4.3	Administrator and operator logs	Y	Actions by system administrators are logged.	ISMS Operational Manual
A.12.4.4	Clock synchronisation	Y	System clocks are synched to ensure accurate log timestamps.	ISMS Operational Manual

A.12.5 Control of Operational Software

Control	Description	Adopted	Justification	Reference
A.12.5.1	Installation of software on operational systems	Y	Software installations are controlled on systems handling patient data.	ISMS Operational Manual

A.12.6 Technical vulnerability Management

Control	Description	Adopted	Justification	Reference
A.12.6.1	Management of technical vulnerabilities	Y	Vulnerabilities are tracked and addressed on data systems.	ISMS Operational Manual
A.12.6.2	Restrictions on software installation	Y	Only authorised software is permitted on systems with patient data.	ISMS Operational Manual

A.12.7.1 Information Systems Audit Considerations

Control	Description	Adopted	Justification	Reference
A.12.7.1	Information systems audit controls	Y	Systems that store patient data are auditable.	Audit & Compliance Logbook

A.13 Communication Security

A.13.1 Network Security Management

Control	Description	Adopted	Justification	Reference
A.13.1.1	Network controls	Y	network controls in place to protect access to patient data.	Information Security Policy Manual
A.13.1.2	Security of network services	Y	Data systems use secure network services to prevent breaches.	Information Security Policy Manual
A.13.1.3	Segregation in networks	N	No network segmentation used for patient data systems.	N/A

A.13.2 Information Transfer

Control	Description	Adopted	Justification	Reference
A.13.2.1	Information transfer policies and procedures	Y	policies define how patient data is shared securely.	Supplier & Third-Party Security Pack
A.13.2.2	Agreements on information transfer	Y	Agreements cover data sharing with clinics and partners.	Supplier & Third-Party Security Pack
A.13.2.3	Electronic messaging	Y	Health data is not sent over unsecured messaging platforms.	Supplier & Third-Party Security Pack
A.13.2.4	Confidentiality or non-disclosure agreements	Y	NDA's are signed by staff handling patient records.	Staff Handbook

A.14 System Acquisition, Development and Maintenance

A.14.1 Security Requirements of Information Systems

Control	Description	Adopted	Justification	Reference
A.14.1.1	Information security requirements analysis and specification	Y	Security requirements are defined for systems handling patient data.	ISMS Operational Manual
A.14.1.2	Securing application services on public networks	Y	Health data systems use secure connections when accessed on public networks.	Information Security Policy Manual
A.14.1.3	Protecting application services transactions	Y	Transactions involving patient data are encrypted.	Information Security Policy Manual

A.14.2 Security in Development and Support Processes

Control	Description	Adopted	Justification	Reference
A.14.2.1	Secure development policy	Y	Secure development practises are followed for health data systems.	ISMS Operational Manual
A.14.2.2	System change control procedures	Y	Changes to data systems are documented and approved.	ISMS Operational Manual
A.14.2.3	Technical review of applications after operating platform changes	N	Not applicable.	N/A
A.14.2.4	Restrictions on changes to software packages	Y	Software updates are restricted on patient data systems.	ISMS Operational Manual
A.14.2.5	Secure system engineering principles	Y	Engineering principles applied to ensure patient data is protected.	ISMS Operational Manual
A.14.2.6	Secure development environment	Y	Environments for health data apps are access controlled.	ISMS Operational Manual
A.14.2.7	Outsourced development	Y	External developers follow contractual security obligations.	Supplier & Third-Party Security Pack

A.14.2.8	System security testing	Y	Health data systems are tested for security before release.	ISMS Operational Manual
A.14.2.9	System acceptance testing	Y	Systems are tested before use with patient records.	Audit & Compliance Logbook

A.14.3 Test Data

Control	Description	Adopted	Justification	Reference
A.14.3.1	Protection of test data	Y	Real patient data is not used in test environment.	ISMS Operational Manual

A.15 Supplier Relationships

A.15.1 Information Security in Supplier Relationships

Control	Description	Adopted	Justification	Reference
A.15.1.1	Information security policy for supplier relationships	Y	Policy defines data security for supplier relationships.	Supplier & Third-Party Security Pack
A.15.1.2	Addressing security within supplier agreements	Y	Supply agreement includes security obligations for patient data.	Supplier & Third-Party Security Pack
A.15.1.3	Information and communication technology supply chain	Y	Information and communication technology supply chain risks of reviewed for hosted patient data systems.	Governance and Continuity Framework

A.15.2 Supplier Service Delivery Management

Control	Description	Adopted	Justification	Reference
A.15.2.1	Monitoring and review of supplier services	Y	Supplier performance is reviewed to maintain security of patient systems.	Supplier & Third-Party Security Pack

A.15.2.2	Managing changes to supplier services	Y	Changes to supplier services are reviewed for security impact	Supplier & Third-Party Security Pack

A.16 Information Security Incident Management

A.16.1 Management of Information Security Incidents and Improvements

Control	Description	Adopted	Justification	Reference
A.16.1.1	Responsibilities and procedures	Y	Defined roles and procedures exist for incident handling.	ISMS Operational Manual
A.16.1.2	Reporting information security events	Y	Staff report security events involving patient data.	Audit & Compliance Logbook
A.16.1.3	Reporting information security weaknesses	Y	Users are encouraged to report potential weaknesses.	Staff Handbook
A.16.1.4	Assessment of and decision on information security events	Y	Events involving health data are assessed and escalated.	Incident response SOP
A.16.1.5	Response to information security incidents	Y	Incident responses are in place to protect patient data.	ISMS Operational Manual
A.16.1.6	Learning from information security incidents	Y	Lessons learned from incidents are reviewed and documented.	Audit & Compliance Logbook
A.16.1.7	Collection of evidence	Y	Procedures ensure evidence is collected in response to incidents.	ISMS Operational Manual

A.17 Information Security Aspects of Business Continuity Management

A.17.1 Information Security Continuity

Control	Description	Adopted	Justification	Reference

A.17.1.1	Planning information security continuity	Y	Continuity plans address patient data during service disruption.	Governance and Continuity Framework
A.17.1.2	Implementing information security continuity	Y	Security measures are in place to maintain data availability.	Governance and Continuity Framework
A.17.1.3	Verify, review and evaluate information security continuity	Y	Information security continuity is reviewed and tested for patient data systems.	Governance and Continuity Framework

A.17.2 Redundancies

Control	Description	Adopted	Justification	Reference
A.17.2.1	Availability of information processing facilities	Y	Information processing facilities used for patient data have safeguards in place to ensure availability.	Supplier & Third-Party Security Pack

A.18 Compliance

A.18.1 Compliance with Legal and Contractual Requirements

Control	Description	Adopted	Justification	Reference
A.18.1.1	Identification of applicable legislation and contractual requirements	Y	legal and contractual obligations for patient data are identified.	Governance and Continuity Framework
A.18.1.2	Intellectual property rights	N	Not relevant.	N/A
A.18.1.3	Protection of records	Y	Patient data is protected as part of organisational records.	Governance and Continuity Framework
A.18.1.4	Privacy and protection of personally identifiable information	Y	Patient data is protected in line with privacy legislation.	Audit & Compliance Logbook
A.18.1.5	Regulation of cryptographic controls	Y	Encryption controls used for health data follow regulation.	Cryptographic control policy

A.18.2 Information Security Reviews

Control	Description	Adopted	Justification	Reference
A.18.2.1	Independent review of information security	Y	Security measures for patient data are periodically reviewed externally.	Audit & Compliance Logbook
A.18.2.2	Compliance with security policies and standards	Y	Compliance with patient data security policies and standards is verified through regular checks.	Information Security Policy Manual
A.18.2.3	Technical compliance review	Y	Technical controls are reviewed to ensure compliance.	Audit & Compliance Logbook